

ASSIGNMENT – C02AT03

COURSE: DEVSECOPS ENGINEERING AND APPLICATION SECURITY

CODE: CSA5803

Submitted By

Name: Harish T

Reg No: 192521373

CASE STUDY – PART 3

Secure Workflow Mapping, Threat Modelling and Architecture Diagram Submission

TITLE

Design a secure logistics and fleet management system architecture identifying attack surfaces and mitigation strategies.

1. Introduction

A Logistics and Fleet Management System (LFMS) coordinates vehicles, drivers, routes, shipments, deliveries, maintenance and operational information. Because it connects mobile users, vehicle telematics, IoT devices, APIs, cloud services and databases, it has a broad attack surface.

The secure design applies layered controls across identity, communication, application, device, network, data and monitoring layers.

2. Objectives

- Map the secure logistics workflow.
- Identify major attack surfaces.
- Perform STRIDE-based threat modelling.
- Define mitigation strategies for identified threats.
- Design a secure architecture with trust boundaries and controls.
- Protect fleet, driver, shipment and customer information.
- Maintain confidentiality, integrity and availability.

3. System Actors

- Fleet Administrator – manages vehicles, users and permissions.
- Dispatcher – assigns vehicles, drivers, shipments and routes.
- Driver – uses mobile and vehicle-connected services.
- Customer – checks shipment and delivery information.
- Vehicle/Telematics Device – provides GPS and vehicle status.
- External Partner – exchanges approved information through APIs.
- Security Administrator – monitors alerts and incidents.

4. Secure Workflow Mapping

The secure workflow begins with authenticated access and continues through vehicle assignment, route planning, tracking, delivery, protected storage and security monitoring.

Stage	Activity	Security Controls
1. Authentication	User signs in through approved application.	MFA, secure sessions, RBAC
2. Vehicle/Driver Assignment	Dispatcher assigns driver and vehicle.	Authorization, audit logs, integrity checks
3. Route Planning	System creates and distributes routes.	API security, role separation, change logging
4. Vehicle Tracking	GPS/telematics sends location and status.	Device identity, TLS, anomaly detection
5. Shipment Tracking	Shipment status is updated during transport.	Access control, encryption, integrity validation
6. Delivery Confirmation	Driver/customer confirms delivery.	Authenticated transaction, timestamp, audit trail
7. Data Storage	Operational data is stored securely.	Encryption, least privilege, backups
8. Monitoring	Security events are collected and analysed.	SIEM, IDS/IPS, EDR

Secure Workflow Principles

- Verify identity before access.
- Authorize according to role and task.
- Encrypt information in transit and at rest.
- Authenticate vehicle and IoT devices.
- Record security-sensitive actions.
- Continuously monitor important events.

5. Attack Surface Analysis

An attack surface is the set of interfaces, devices, applications, communication channels, accounts and data stores through which an attacker could attempt to compromise the system.

Attack Surface	Potential Threat	Mitigation
Driver Mobile App	Credential theft, session compromise	MFA, secure sessions, device management
GPS/Telematics	Device compromise, GPS spoofing	Device authentication, TLS, anomaly detection
API Gateway	Injection, unauthorized requests	Authentication, validation, rate limiting, WAF
Cloud Application	Misconfiguration, identity compromise	Least privilege, secure configuration, monitoring
Database	Unauthorized access or modification	Encryption, RBAC, auditing, backups
Employee Endpoints	Phishing, malware, stolen credentials	EDR, awareness training
External APIs	Third-party compromise or API abuse	Scoped tokens, authentication, monitoring
Network/Wireless	Interception, unauthorized access	TLS, segmentation, secure configuration

High-Priority Attack Surfaces

- Vehicle and telematics interfaces.
- Identity and authentication systems.
- APIs connecting applications and partners.
- Databases containing operational information.
- Administrative endpoints with privileged access.

6. Threat Modelling using STRIDE

STRIDE provides a structured method for identifying common threat categories in the proposed architecture.

Threat	Logistics Scenario	Mitigation
Spoofing	Impersonating driver, dispatcher, administrator, device or API client.	MFA, device identity, strong authentication
Tampering	Changing route, shipment, GPS or vehicle information.	Integrity validation, signed data, RBAC, logs
Repudiation	User denies a sensitive action such as route modification.	Centralized logs, timestamps, audit trails

Information Disclosure	Unauthorized access to driver, location or shipment data.	Encryption, RBAC, data minimization
Denial of Service	Disrupting APIs, applications or tracking services.	Rate limiting, redundancy, DDoS protection, recovery
Elevation of Privilege	Compromised account gains administrative access.	Least privilege, PAM, MFA, monitoring

Threat Propagation Example

A compromised driver credential can propagate from the mobile application to the API layer when authentication and authorization are weak. The attacker may then attempt to access shipment or route services and eventually protected data. MFA, RBAC, API validation, segmentation, least privilege and monitoring reduce this propagation path.

7. Mitigation Strategies

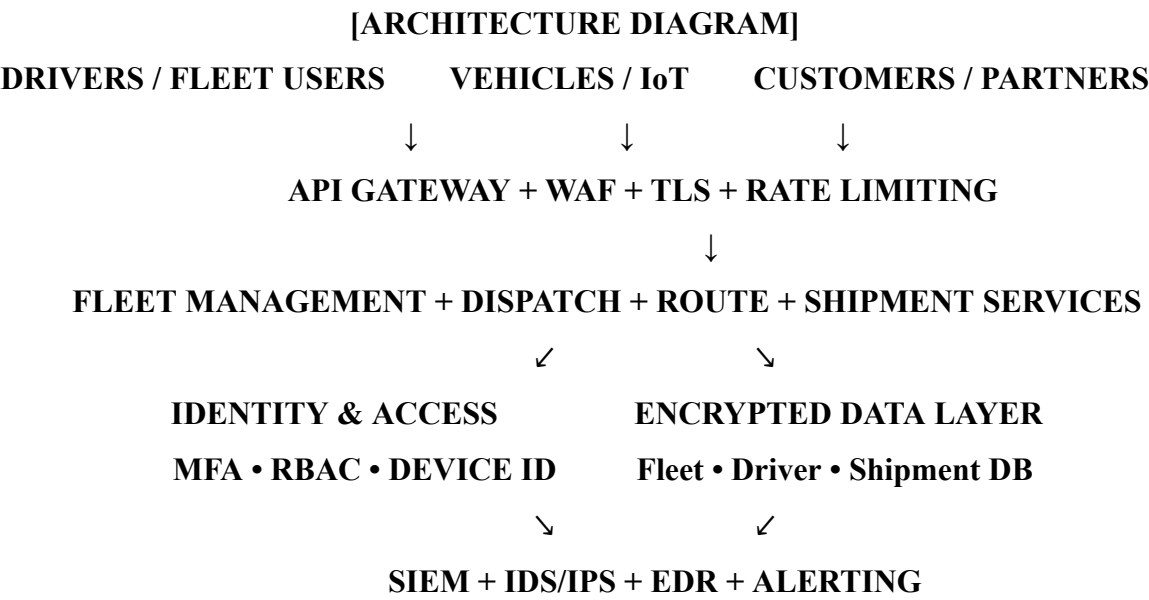
Security Area	Mitigation Controls
Identity & Access	MFA, RBAC, least privilege, privileged access management
Network	Segmentation, TLS, firewalls, IDS/IPS
Application	Secure coding, input validation, WAF, API gateway, rate limiting
Vehicle/IoT	Device identity, authenticated communication, secure firmware
Data	Encryption, key management, access restrictions, backups
Endpoint	EDR, patching, secure configuration, malware protection
Monitoring	SIEM, centralized logging, anomaly detection, alerting
Resilience	Redundancy, disaster recovery, incident response

Security Design Principles

- Zero Trust – do not trust users or devices by default.
- Least Privilege – provide only required access.
- Defense in Depth – use multiple security layers.
- Secure by Design – include security during architecture and development.
- Continuous Monitoring – detect abnormal activity.
- Resilience – maintain availability through recovery controls.

8. Secure Architecture Diagram

The architecture below maps the major users, connected vehicles, security gateway, application services, identity controls, data layer and security operations.



Architecture Layer Explanation

- User/Device Layer – drivers, fleet users, customers and vehicles.
- Security Gateway – API Gateway and WAF enforce authentication, validation, TLS and rate limiting.
- Application Layer – fleet, dispatch, route and shipment services perform business operations.
- Identity Layer – MFA, RBAC and device identity reduce unauthorized access.
- Data Layer – sensitive data is encrypted and access controlled.
- Security Operations – SIEM, IDS/IPS and EDR support continuous monitoring.

9. Secure Workflow and Architecture Mapping

Workflow	Architecture Path	Controls
Authentication	Mobile/Web → Identity & Access	MFA, RBAC, secure sessions
Dispatch	Dispatcher → API Gateway → Application	Authorization, logging, validation
Vehicle Tracking	Vehicle/IoT → API Gateway → Application	Device identity, TLS, anomaly detection
Shipment Update	Driver App → API Gateway → Shipment Service	Token validation, integrity checks
Database Access	Application → Data Layer	Least privilege, encryption, auditing
Security Monitoring	All layers → SIEM	Centralized logging, alerting, correlation

10. Expected Security Outcomes

- Reduced unauthorized access.
- Improved protection of fleet, driver, shipment and customer data.
- Reduced impact of compromised accounts and devices.
- Better detection of suspicious API, identity, endpoint and vehicle activity.
- Improved integrity of routes, shipment records and telemetry.
- Improved availability through resilience and recovery.
- Clear mapping between attack surfaces, threats and mitigation strategies.

11. Conclusion

The proposed design addresses the Part 3 requirement through secure workflow mapping, attack surface analysis, STRIDE-based threat modelling, mitigation strategies and an architecture representation. MFA, RBAC, encryption, secure APIs, network segmentation, device identity, monitoring and resilience provide layered protection while supporting reliable fleet operations.

References / Supporting Security Concepts

- OWASP – Web and API security concepts.
- NIST – Cybersecurity Framework and Zero Trust Architecture concepts.
- CISA – Cybersecurity guidance for connected systems and critical infrastructure.
- STRIDE – Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.